ZAP by Checkmarx Scanning Report

Generated with ZAP on 週一 23 3月 2026, at 11:20:13

ZAP Version: 2.16.1

ZAP by Checkmarx

Contents

- About This Report
  - Report Parameters
- Summaries
  - Alert Counts by Risk and Confidence
  - Alert Counts by Site and Risk
  - Alert Counts by Alert Type
- Alerts
  - Risk=Low, Confidence=High (2)
  - Risk=Low, Confidence=Medium (4)
  - Risk=Informational, Confidence=High (2)
  - Risk=Informational, Confidence=Medium (11)
  - Risk=Informational, Confidence=Low (2)
- Appendix
  - Alert Types

About This Report

Report Parameters

Contexts

The following contexts were selected to be included:

- https://apsvp.atri.org.tw

Sites

The following sites were included:

- https://apsvp.atri.org.tw

(If no sites were selected, all sites were included by default.)

An included site must also be within one of the included contexts for its data to be included in the report.

Risk levels

Included: High, Medium, Low, Informational

Excluded: None

Confidence levels

Included: User Confirmed, High, Medium, Low

Excluded: User Confirmed, High, Medium, Low, False Positive

Summaries

Alert Counts by Risk and Confidence

This table shows the number of alerts for each level of risk and confidence included in the report.

(The percentages in brackets represent the count as a percentage of the total number of alerts included in the report, rounded to one decimal place.)

		Confidence				
		User Confirmed	High	Medium	Low	Total
Risk	High	0 (0.0%)	0 (0.0%)	0 (0.0%)	0 (0.0%)	0 (0.0%)
	Medium	0 (0.0%)	0 (0.0%)	0 (0.0%)	0 (0.0%)	0 (0.0%)
	Low	0 (0.0%)	2 (8.3%)	4 (16.7%)	0 (0.0%)	6 (25.0%)
	Informational	0 (0.0%)	2 (8.3%)	11 (45.8%)	2 (8.3%)	15 (62.5%)
	Total	0 (0.0%)	5 (20.8%)	17 (70.8%)	2 (8.3%)	24 (100%)

Alert Counts by Site and Risk

This table shows, for each site for which one or more alerts were raised, the number of alerts raised at each risk level.

Alerts with a confidence level of "False Positive" have been excluded from these counts.

(The numbers in brackets are the number of alerts raised for the site at or above that risk level.)

		Risk			
		High (= High)	Medium (>= Medium)	Low (>= Low)	Informational (>= Informational)
Site	https://apsvp.atri.org.tw	0 (0)	0 (0)	3 (3)	14 (14)

Alert Counts by Alert Type

This table shows the number of alerts of each alert type, together with the alert type's risk level.

(The percentages in brackets represent each count as a percentage, rounded to one decimal place, of the total number of alerts included in this report.)

Alert type	Risk	Count
Cookie No HttpOnly Flag	Low	3 (12.5%)
Cookie without SameSite Attribute	Low	6 (25.0%)
Cross-Domain JavaScript Source File Inclusion	Low	8 (33.3%)
Server Leaks Version Information via "Server" HTTP Response Header Field	Low	123 (512.5%)
X-Content-Type-Options Header Missing	Low	55 (229.2%)
ZAP is Out of Date	Low	1 (4.2%)
Authentication Request Identified	Informational	1 (4.2%)
Information Disclosure - Information in Browser localStorage	Informational	1 (4.2%)
Information Disclosure - Suspicious Comments	Informational	21 (87.5%)
Modern Web Application	Informational	12 (50.0%)
Session Management Response Identified	Informational	7 (29.2%)
Total		24

Alert type	Risk	Count
Tech Detected - Bootstrap	Informational	1 (4.2%)
Tech Detected - Django	Informational	1 (4.2%)
Tech Detected - Font Awesome	Informational	1 (4.2%)
Tech Detected - Google Font API	Informational	1 (4.2%)
Tech Detected - Google Hosted Libraries	Informational	1 (4.2%)
Tech Detected - cdnjs	Informational	1 (4.2%)
Tech Detected - jQuery	Informational	1 (4.2%)
Tech Detected - jQuery UI	Informational	1 (4.2%)
Tech Detected - jsDelivr	Informational	1 (4.2%)
User Controllable HTML Element Attribute (Potential XSS)	Informational	4 (16.7%)
Total		24

Alerts

Risk=Low, Confidence=High (2)

Risk=Low, Confidence=Medium (4)

https://apsvp.atri.org.tw (3)

Cookie No HttpOnly Flag (1)

▶ GET https://apsvp.atri.org.tw/accounts/login/

Cookie without SameSite Attribute (1)

▶ GET https://apsvp.atri.org.tw/

Cross-Domain JavaScript Source File Inclusion (1)

▶ GET https://apsvp.atri.org.tw/accounts/login/

Risk=Informational, Confidence=High (2)

https://apsvp.atri.org.tw (2)

Authentication Request Identified (1)

▶ POST https://apsvp.atri.org.tw/accounts/login/

Information Disclosure - Information in Browser localStorage (1)

▶ GET https://apsvp.atri.org.tw/

Risk=Informational, Confidence=Medium (11)

https://apsvp.atri.org.tw (11)

Modern Web Application (1)

▶ GET https://apsvp.atri.org.tw/accounts/login/

Session Management Response Identified (1)

▶ GET https://apsvp.atri.org.tw/

Tech Detected - Bootstrap (1)

▶ GET https://apsvp.atri.org.tw/accounts/login/

Tech Detected - Django (1)

▶ GET https://apsvp.atri.org.tw/accounts/login/

Tech Detected - Font Awesome (1)

▶ GET https://apsvp.atri.org.tw/accounts/login/

Tech Detected - Google Font API (1)

▶ GET https://apsvp.atri.org.tw/accounts/login/

Tech Detected - Google Hosted Libraries (1)

▶ GET https://apsvp.atri.org.tw/accounts/login/

Tech Detected - cdnjs (1)

▶ GET https://apsvp.atri.org.tw/zh-hant/

Tech Detected - jQuery (1)

▶ GET https://apsvp.atri.org.tw/accounts/login/

Tech Detected - jQuery UI (1)

▶ GET https://apsvp.atri.org.tw/zh-hant/

Tech Detected - jsDelivr (1)

▶ GET https://apsvp.atri.org.tw/zh-hant/

Risk=Informational, Confidence=Low (2)

https://apsvp.atri.org.tw (1)

User Controllable HTML Element Attribute (Potential XSS) (1)

▶ POST https://apsvp.atri.org.tw/dailytrans/festival-report/render/

Appendix

Alert Types

This section contains additional information on the types of alerts in the report.

Cookie No HttpOnly Flag

Source	raised by a passive scanner (Cookie No HttpOnly Flag)
CWE ID	1004
WASC ID	13
Reference	▪ https://owasp.org/www-community/HttpOnly

Cookie without SameSite Attribute

Source	raised by a passive scanner (Cookie without SameSite Attribute)
CWE ID	1275
WASC ID	13
Reference	▪ https://datatracker.ietf.org/doc/html/draft-ietf-httpbis-cookie-same-site

Cross-Domain JavaScript Source File Inclusion

Source	raised by a passive scanner (Cross-Domain JavaScript Source File Inclusion)
CWE ID	829
WASC ID	15

Server Leaks Version Information via "Server" HTTP Response Header Field

Source	raised by a passive scanner (HTTP Server Response Header)
CWE ID	497

WASC ID	13
Reference	▪ https://httpd.apache.org/docs/current/mod/core.html#servertokens ▪ https://learn.microsoft.com/en-us/previous-versions/msp-n-p/ff648552(v=pandp.10) ▪ https://www.troyhunt.com/shhh-dont-let-your-response-headers/

X-Content-Type-Options Header Missing

Source	raised by a passive scanner (X-Content-Type-Options Header Missing)
CWE ID	693
WASC ID	15
Reference	▪ https://learn.microsoft.com/en-us/previous-versions/windows/internet-explorer/ie-developer/compatibility/gg622941(v=vs.85) ▪ https://owasp.org/www-community/Security_Headers

ZAP is Out of Date

Source	raised by a passive scanner (ZAP is Out of Date)
CWE ID	1104
WASC ID	45
Reference	▪ https://www.zaproxy.org/download/

Authentication Request Identified

Source	raised by a passive scanner (Authentication Request Identified)

Reference	▪ https://www.zaproxy.org/docs/desktop/addons/authentication-helper/auth-req-id/

Information Disclosure - Information in Browser localStorage

Source	raised by a passive scanner (plugin ID: 120000)
CWE ID	359
WASC ID	13

Information Disclosure - Suspicious Comments

Source	raised by a passive scanner (Information Disclosure - Suspicious Comments)
CWE ID	615
WASC ID	13

Modern Web Application

Source	raised by a passive scanner (Modern Web Application)

Session Management Response Identified

Source	raised by a passive scanner (Session Management Response Identified)
Reference	▪ https://www.zaproxy.org/docs/desktop/addons/authentication-helper/session-mgmt-id/

Tech Detected - Bootstrap

Source	raised by other tools/functionalities in ZAP (for example, fuzzer, HTTPS Info add-on, custom scripts...) (plugin ID: 10004)
WASC ID	13

Reference	▪ https://getbootstrap.com

Tech Detected - Django

Source	raised by other tools/functionalities in ZAP (for example, fuzzer, HTTPS Info add-on, custom scripts...) (plugin ID: 10004)
WASC ID	13
Reference	▪ https://djangoproject.com

Tech Detected - Font Awesome

Source	raised by other tools/functionalities in ZAP (for example, fuzzer, HTTPS Info add-on, custom scripts...) (plugin ID: 10004)
WASC ID	13
Reference	▪ https://fontawesome.com/

Tech Detected - Google Font API

Source	raised by other tools/functionalities in ZAP (for example, fuzzer, HTTPS Info add-on, custom scripts...) (plugin ID: 10004)
WASC ID	13
Reference	▪ https://fonts.google.com/

Tech Detected - Google Hosted Libraries

Source	raised by other tools/functionalities in ZAP (for example, fuzzer, HTTPS Info add-on, custom scripts...) (plugin ID: 10004)
WASC ID	13
Reference	▪ https://developers.google.com/speed/libraries

Tech Detected - cdnjs

Source	raised by other tools/functionalities in ZAP (for example, fuzzer, HTTPS Info add-on, custom scripts...) (plugin ID: 10004)
WASC ID	13
Reference	▪ https://cdnjs.com

Tech Detected - jQuery

Source	raised by other tools/functionalities in ZAP (for example, fuzzer, HTTPS Info add-on, custom scripts...) (plugin ID: 10004)
WASC ID	13
Reference	▪ https://jquery.com

Tech Detected - jQuery UI

Source	raised by other tools/functionalities in ZAP (for example, fuzzer, HTTPS Info add-on, custom scripts...) (plugin ID: 10004)
WASC ID	13
Reference	▪ https://jqueryui.com

Tech Detected - jsDelivr

Source	raised by other tools/functionalities in ZAP (for example, fuzzer, HTTPS Info add-on, custom scripts...) (plugin ID: 10004)
WASC ID	13
Reference	▪ https://www.jsdelivr.com/

User Controllable HTML Element Attribute (Potential XSS)

Source	raised by a passive scanner (User Controllable HTML Element Attribute (Potential XSS))
CWE ID	20
WASC ID	20
Reference	▪ https://cheatsheetseries.owasp.org/cheatsheets/Input_Validation_Cheat_Sheet.html